

08	Unvalidated Redirects (검증되지 않은 리다이렉트)
취약점 개요	
점검 내용	웹 애플리케이션에서 외부에서 전달된 URL 파라미터(예: redirect?to=)를 검증 없이 리다이렉트 처리하는지 확인
점검 목적	사용자가 신뢰할 수 있는 도메인으로 위장한 악성 사이트로 연결되는 것을 방지하여 피싱 및 악성코드 감염을 예방함
보안 위험	- 공격자가 정상적인 도메인의 URL을 조작하여 피해자를 악성 파일이 있는 서버로 유도할 수 있음 - 이메일 등에서 해당 도메인만 보고 클릭한 내부 사용자가 피싱에 노출됨
참고	redirect?to= 파라미터 변조 → 공격자 서버로 리다이렉트 → 악성 문서 다운로드 유도

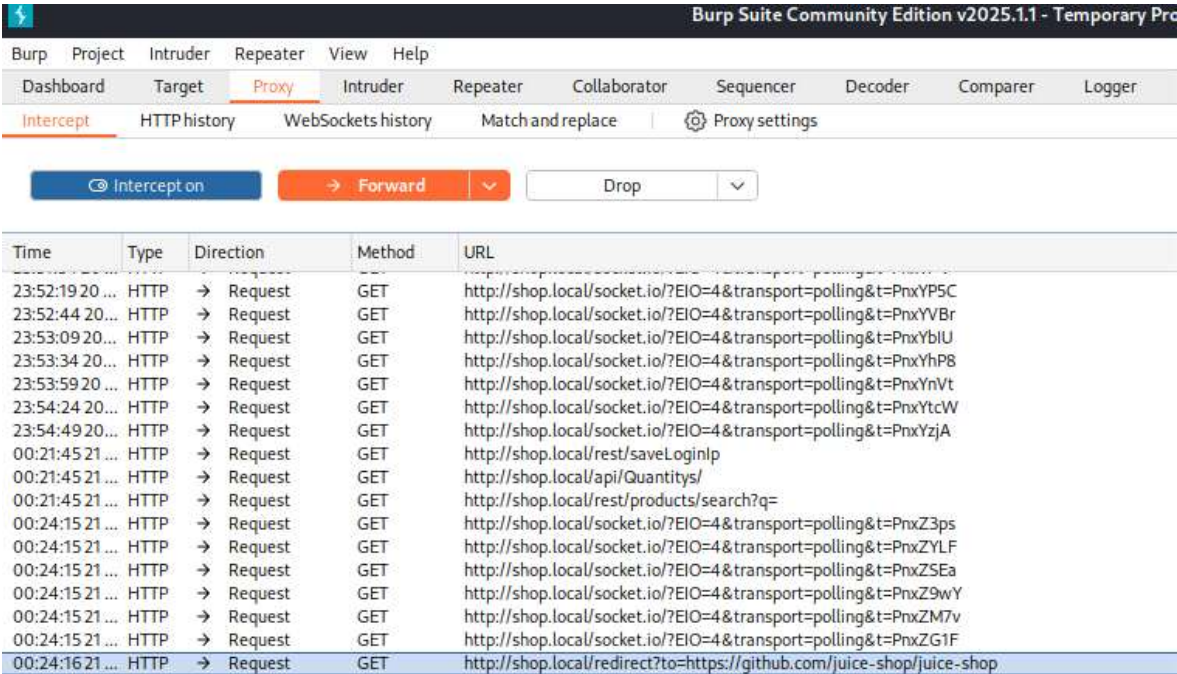
점검대상 및 판단기준	
대상	웹 애플리케이션 소스 코드 (리다이렉트 로직), URL 파라미터
조치방법	리다이렉트되는 목적지 URL을 서버 측에서 사전에 정의된 도메인(White List)으로만 제한 직접적인 URL 대신 인덱스 값(예: redirect=1)을 사용하여 내부 로직에서 처리하도록 수정

점검 및 조치사례

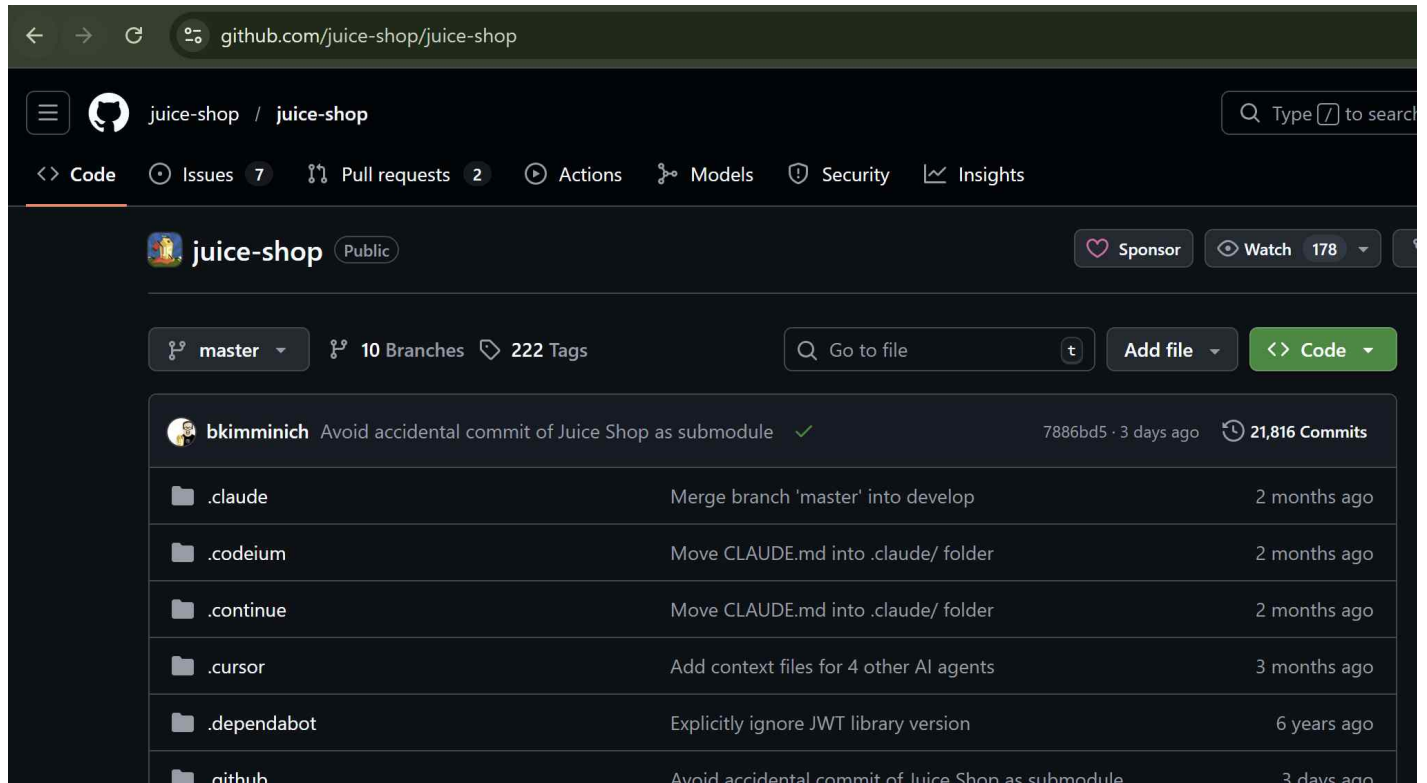
[해당 취약점의 판별법]

1. 애플리케이션 내에서 페이지 이동을 담당하는 파라미터(예: url=, return=, to=, redirect=) 식별
2. 해당 파라미터의 값으로 외부 악성 도메인(예: http://attacker.com) 삽입 후 전송
3. 경고 창이나 차단 없이 해당 도메인으로 즉시 이동된다면 취약점 존재

해당 페이지(shop.local)은 자체 깃허브 주소가 redirect=로 이동 되는 구조



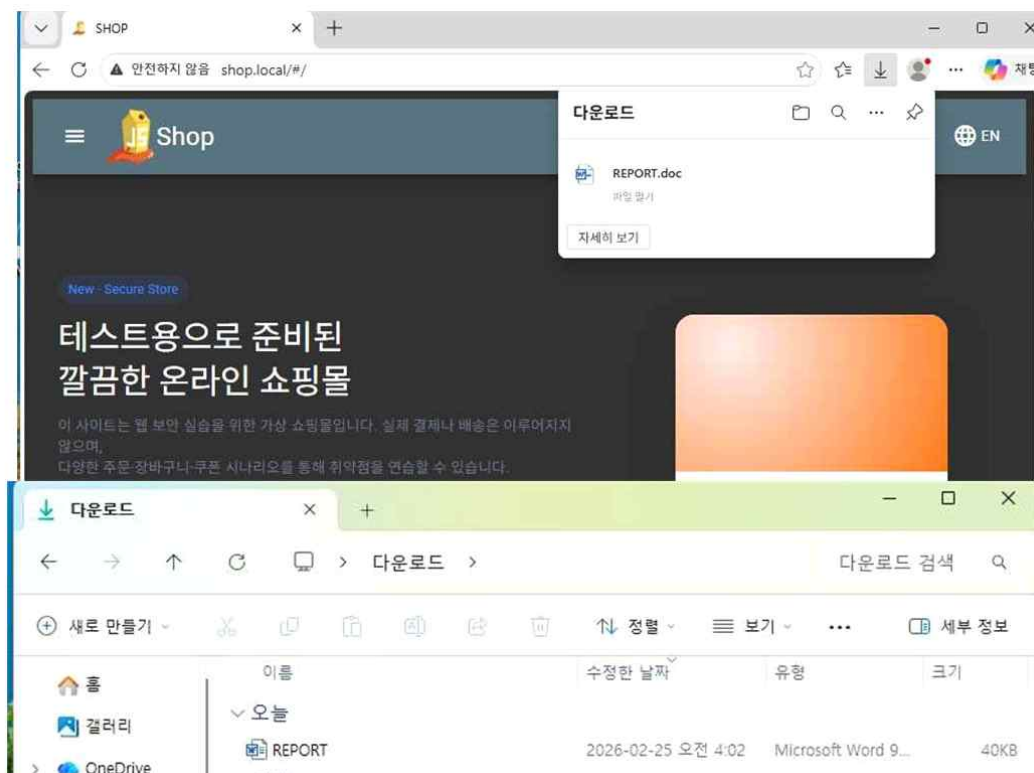
해당 깃허브 주소가 사이트 내에서 리다이렉트 되면서 깃허브와 연결되어 있음.



[점검 및 조치 사례]

1. 취약한 동작 확인

- 주소창에 `http://shop.local/redirect?to=http://malware.com/REPORT.doc` 입력 후 엔터.
- 브라우저가 내부 로직 검증 없이 즉시 악성 파일 다운로드 경로로 이동하는 것을 확인.



2. 보안 방법 및 조치

- 사용자가 전달한 URL 값을 목적지로 바로 사용하지 않아야 합니다.
- 부득이하게 사용해야 할 경우, 사전에 정의된 도메인(White List)인지 검증하거나, URL 대신 인덱스(Index) 값을 사용하여 서버 내부에서 매핑된 주소로 이동하도록 처리합니다.

[안전하지 않은 코드 (JSP)]

```
<%  
String url = request.getParameter("to");  
response.sendRedirect(url); // 검증 없이 바로 리다이렉트  
%>
```

[안전한 코드 (JSP - 화이트리스트 검증)]

```
<%  
String url = request.getParameter("to");  
String[] allowedUrls = {"/home.jsp", "/notice.jsp", "http://shop.local/help"};  
boolean isAllowed = false;  
  
for(String allowed : allowedUrls) {  
    if(allowed.equals(url)) {  
        isAllowed = true;  
        break;  
    }  
}  
  
if(isAllowed) {  
    response.sendRedirect(url);  
} else {  
    response.sendRedirect("/error.jsp"); // 비정상 요청 시 에러 페이지로 이동  
}  
%>
```